

PIEDPIN

CISSP for BEGINNER

なぜCISSPを学ぶのか

- ✓ CISSP(Certified Information Systems Security Professional)とは、世界標準の**セキュリティ・プロフェッショナル認定**です。
- ✓ (ISC)²（国際情報システムセキュリティ認証コンソーシアム、International Information Systems Security Certification Consortium）が認定を行っています。
- ✓ 情報セキュリティ専門家が共通言語として利用している『(ISC)² CISSP CBK』を理解している者のみに与えられる資格です。
- ✓ 2004年6月に、米国規格協会（ANSI）より**ISO/IEC17024**の認証を受け、信頼度がより高くなりました。（https://japan.isc2.org/cissp_about.html）
- ✓ 2022年7月1日現在、日本のCISSPは**3,699**人となっています。（<https://japan.isc2.org/>）

(ISC)² が展開する資格ソリューション



国際的に認められた情報セキュリティ・プロフェッショナル認定資格です。米国規格協会（ANSI）よりISO/IEC17024の認証を受けた。



ベンダーフリー・カントリーフリーの情報セキュリティの資格です。情報セキュリティに従事しないが、組織を理解し、適切なコミュニケーションを行う。



クラウドサービスを安全に利用するために必要な知識を体系化した資格です。



ソフトウェアの脆弱性に端を発したセキュリティインシデントの増加や、政府や重要インフラにおけるセキュアなソフトウェアニーズに対応する資格です。

(ISC)² CISSP CBK ドメイン



ドメイン 1
セキュリティとリスク
マネジメント



ドメイン 2
資産のセキュリティ



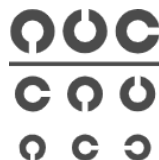
ドメイン 3
セキュリティアーキ
テクチャとエンジニ
アリング



ドメイン 4
通信とネットワー
クのセキュリティ



ドメイン 5
アイデンティティと
アクセスの管理



ドメイン 6
セキュリティの評
価とテスト



ドメイン 7
セキュリティの運用



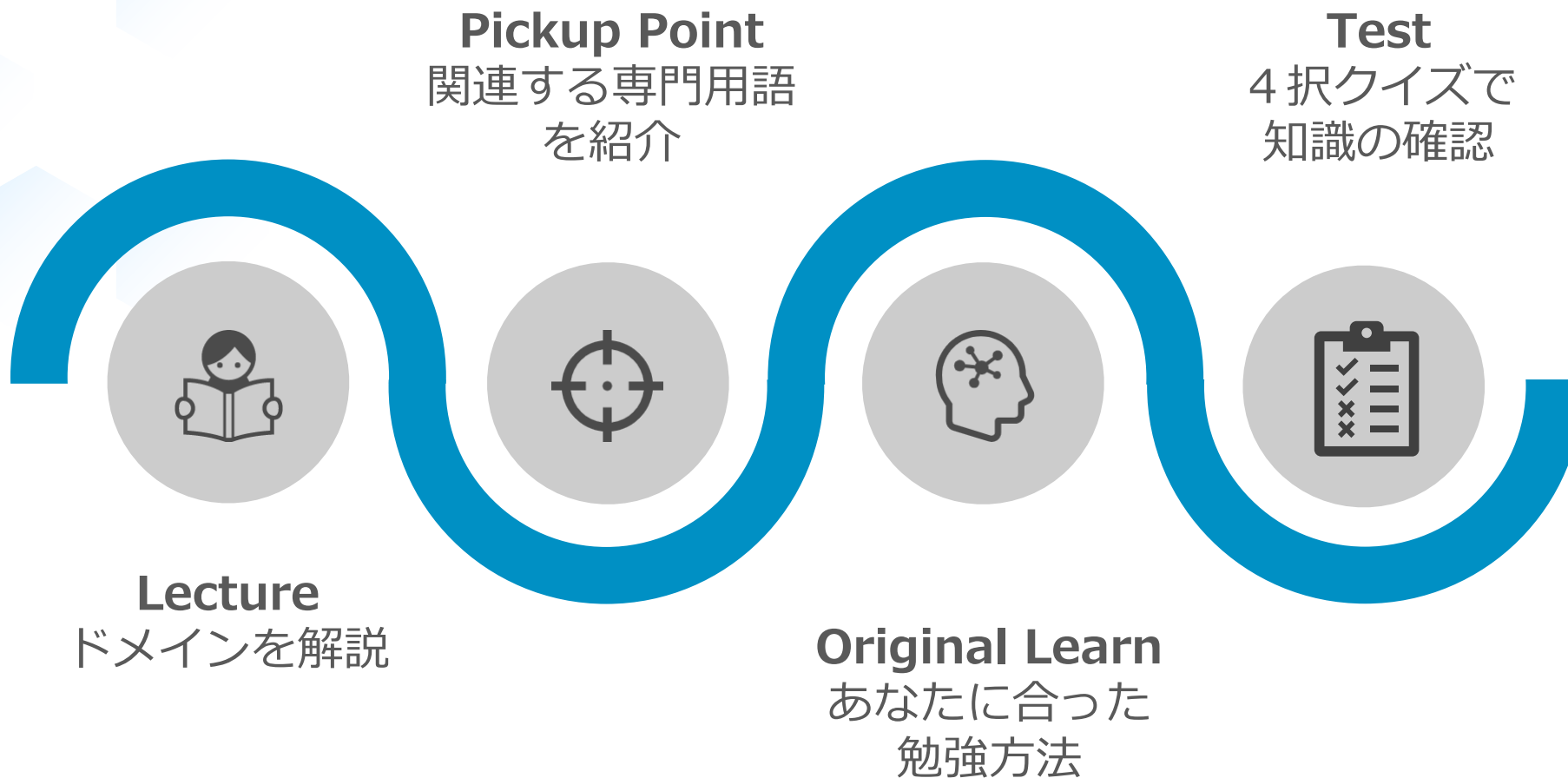
ドメイン 8
ソフトウェア開発
セキュリティ

あなたのゴールとレッスンの役割

- ✓ 情報セキュリティ初心者のために設計されたCISSP講座
経験者からすると“当たり前”と感じる内容も含まれます。
- ✓ 本レッスンの対象は、CBKのドメイン 5 です。
他のドメインのレッスンは対象外となります。
- ✓ CISSP合格のためのアップグレードが必要です。
現代のセキュリティの関心、流行、考え方を織り込みます。



レッスンの流れ



CISSP試験のドメイン別試験比重



ドメイン 1
セキュリティとリスク
マネジメント

15%



ドメイン 2
資産のセキュリティ

10%



ドメイン 3
セキュリティアーキテ
クチャとエンジニアリ
ング

13%



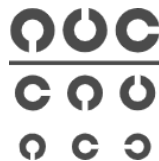
ドメイン 4
通信とネットワー
クのセキュリティ

13%



ドメイン 5
アイデンティティとア
クセスの管理

13%



ドメイン 6
セキュリティの評価
とテスト

12%



ドメイン 7
セキュリティの運用

13%



ドメイン 8
ソフトウェア開発セ
キュリティ

11%

DOMAIN 5 のカテゴリー



認証

- 認証方式



認可

- アクセス制御
- 制御システム



不正ログイン

- 不正ログイン



アカウント管理

- プロビジョニング



認証基盤

- 認証基盤
- シングルサインオン



認証

関連用語

- AAAプロトコル
- 多要素認証
- パスワード認証
- スマートカード
- 動的トークン
- チャレンジレスポンス認証
- 生体認証
- FIDO
- アウトオブバンド特定証明

認証

AAAプロトコル

●AAAプロトコル (IAAA)

識別 (Identity)

- ログインIDなど、システムが本人を特定することです。

認証 (Authentication)

- 本人かどうかを確認することです。
- Type1 (something you know) とは、記憶による認証です。
- Type2 (something you have) とは、所持物による認証です。
- Type3 (something you are) とは、身体・生体による認証です。
- Type4 (somewhere you are) とは、位置情報による認証です。
- Type5 (something you do) とは、行動による認証です。

認可 (Authorization)

- アクセス制御など、認証が済んだ後にユーザーが要求可能な処理を判定することです。

計上・監査 (Accounting/Auditing)

- システムログなど、ユーザーもしくはシステムが何をしたかを記録しておくことです。

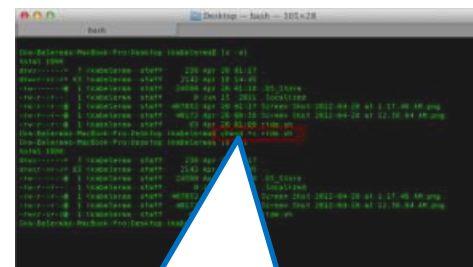
識別
認証

パスワード認証、
生体認証



認可

アクセス制御



`-rw-r--r-- tom users memo.txt`

※memo.txtにtomユーザーが読み取り
権限と書き込み権限を持っている例

計上
監査

システムログ、
トランザクション



各処理に対してトラン
ザクションIDを付与し、
一連の処理が紐づく
ようにする。

認証

多要素認証

● 認証タイプ

Type1 (something you know)

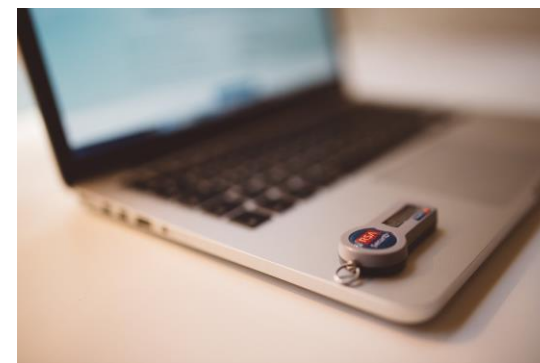
- パスワード認証やPIN認証、秘密の質問のように人の記憶を認証情報として扱う認証方式群です。
- 例) パスワード認証、PIN認証、秘密の質問

Type2 (something you have)

- ICカードやトークンのように機器を持っていることを認証判定として扱う認証方式群です。
- 認証のためにアクセスを許可した所持者に渡すものをトークンといいます。トークンで認証するには、トークン固有でありながら毎回異なる値を認証側に提示する必要があります。
- 例) ハードウェアトークン、ソフトウェアトークン、スマートカード、ICカード

Type3 (something you are)

- 指紋や顔など、自分の体の特徴を使った生体認証方式群です。
- 生体認証は何かを記憶することもなく、何かを所持する必要もなく使い勝手の良い認証であると言えます。
- その一方で、身体に対する特徴付けによりユーザー固有のものであることをシステムとして判断しなければなりません。ただ、病気の時など体調の優れないときは、正常時を維持することが難しいでしょう。こういった状態を取り込みつつ、固有の特徴として区別しなければなりません。
- 例) 指紋、顔、網膜



認証

多要素認証



● 認証タイプ

Type4 (somewhere you are)

- 認証者の現在地により本人であることを確認する認証方式群です。
- 日本にある施設からしかアクセスのみ許可したいシステムなどのに適用し、他国からのアクセスはIPアドレスは認証不可とする。
- 例) GPS位置情報、IPアドレス



Type5 (something you do)

- 歩き方など、身体的特徴ではなく習慣化している癖によって本人を確認する認証方式群です。
- この認証方式の一部は行動系のType3の生体認証情報としてカテゴライズされる場合もあります。
- 例) 筆跡、歩行癖



● 多要素認証 (MFA、Multi-Factor Authentication)

多要素認証とは、異なる認証タイプを組み合わせることで利用することです。

同じ認証タイプを2回呼び出しても、多要素認証にはなりません。この場合、単に多段認証と呼ばれます。

クレジットカードに利用されている認証では、クレジットカードの所持 (Type2) とPIN (Type1) の組み合わせであり、多要素認証となります。(ただし、オンライン決済の場合、クレジットカードの所持による特性はないため、多要素認証とは呼べないでしょう。)

認証

認証タイプ1

●タイプ1：記憶による認証方式

パスワード認証は世界で最も有名な認証方式です。パスワード認証は、ログイン画面にログインIDとともにパスワードを入力し、認証する認証方式です。非常に多くのITシステムがこの認証方式に頼っています。オンラインバンキングやWebメール、ソーシャルアカウントへのログインがパスワード認証を使っています。

静的パスワード

- 静的パスワードとは、一般的な言うパスワードであり、自身に変更するまでは認証に同じパスワードを使いまわせるものです。
- あなたが、あるサイトにログインするとき以前と同じパスワードで認証することができます。

パズフレーズ

- パズフレーズとは、文字列というよりも文章をパスワードを扱うものです。秘密の質問がこのケースに当てはまります。
- 残念なことに文章というのは規則性があり、推測しやすくなる傾向がある。パスワード文字が長い代わりにランダム性を失っているとも言え換えられます。



秘密の質問は終わり

2015年5月、Google社はGoogleアカウントの復旧に使用された数億件の秘密の質問について、その答えをクラッカーがどのくらい正解できるのかを調査しました。（「Secrets, Lies, and Account Recovery: Lessons from the Use of Personal Knowledge Questions at Google」、<https://research.google/pubs/pub43783/>）結論として、秘密の質問はそれ単体ではアカウント復旧の仕組みとして使用するには安全性はないと、されました。



認証

認証タイプ1

●タイプ1：記憶による認証方式

ワンタイムパスワード

- ワンタイムパスワードは、認証ごとにパスワードが変更するものです。
- 一度利用されたパスワードは2回目以降も使われる確証はなく、静的パスワード認証よりもセキュアであると言えます。
- 「記憶による認証方式」で説明されるワンタイムパスワードはデバイスを使用していません。それだと、「所持による認証方式」になってしまいます。決められた連絡による通知や事前に口頭で伝えられたルールに基づいてワンタイムパスワードが発行されるものと解釈ください。

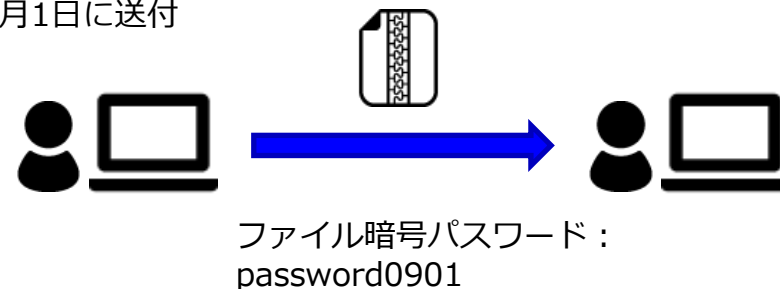
動的パスワード

- 動的パスワードは、定期的に変更になるパスワードです。時間経過によりパスワードが変更します。
- ワンタイムパスワードには、パスワード発行されてから認証を行うまでの間、ワンタイムパスワードは変更できませんが、動的パスワードの場合は定期で自動的に変更されます。
- ワンタイムパスワードと同様に「記憶による認証方式」で説明される動的パスワードはデバイスを使用していません。連携ファイルの暗号化に日時をいれているなどのケースがあります。



動的パスワード（記憶）の例

9月1日に送付



9月17日に送付





●タイプ2：所持による認証方式

スマートカード

- 非接触型のスマートカードにはICC（Integrated Circuit Card）を使用したコンピューター回路が内蔵されています。読み取り機に挿入するとRFID（Radio Frequency Identification）を使用しRFIDトランシーバーによって読み取られます。
- 磁気ストライプカードは、コンピューター回路を内包しおらず、リーダーをスワイプすることで読み取ります。この手のカードは複製は非常に簡単です。

スマートカードの脆弱性

- マイクロプローブ技術とは、表面に直接接触して読み取る技術です。これにより、電波放射を盗聴し、物理的な現象を基に推測を試みます。
- 障害生成技術とは、異常な環境条件で誤作動を起こす技術です。
- ソフトウェア攻撃とは、プロトコル・暗号アルゴリズムなどの脆弱性をつきます。



●タイプ2：所持による認証方式

認証器の登録

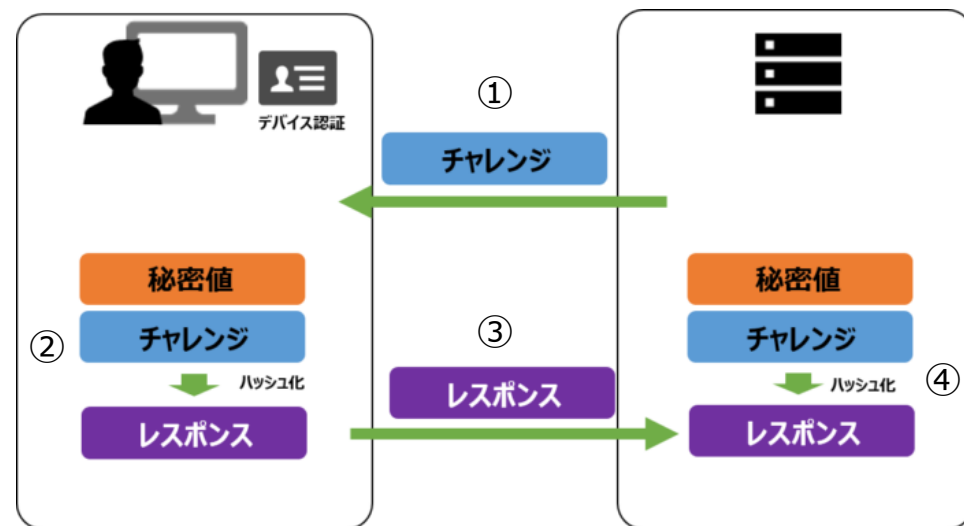
- 利用する認証器は事前に登録が必要です。
- 一般的なシステム処理としては認証サーバから認証器に対して秘密鍵を発行するプロセスです。

非同期動的トークン

- 非同期動的トークンとは、認証サーバとデバイス間で同期する情報を取りえないトークンです。
- 多くの場合、チャレンジレスポンス認証という方法が利用されます。

チャレンジレスポンス認証

- チャレンジレスポンス認証とは、パスワードといった機密情報を通信経路に流すことなく認証を行う方式です。
- 適切なハッシュ化を行うと、衝突を起こさずに一意の値が取得できます。この性質を利用し、サーバからランダムな文字列であるチャレンジに対してパスワードのハッシュ値をレスポンスとして返却します。秘密値（パスワード、秘密鍵など）は通信経路に流れません。その上、チャレンジごとにレスポンスの値が変わるためワンタイムの性質も持ち合わせます。



チャレンジレスポンス認証による非同期動的トークン検証

- ①チャレンジ（ランダム文字列）を連携
- ②事前に連携された秘密鍵（もしくはパスワード）とチャレンジをハッシュ化
- ③レスポンス電文を生成
- ④自環境で算出したハッシュ値とクライアントから受け取ったレスポンスを照合

認証

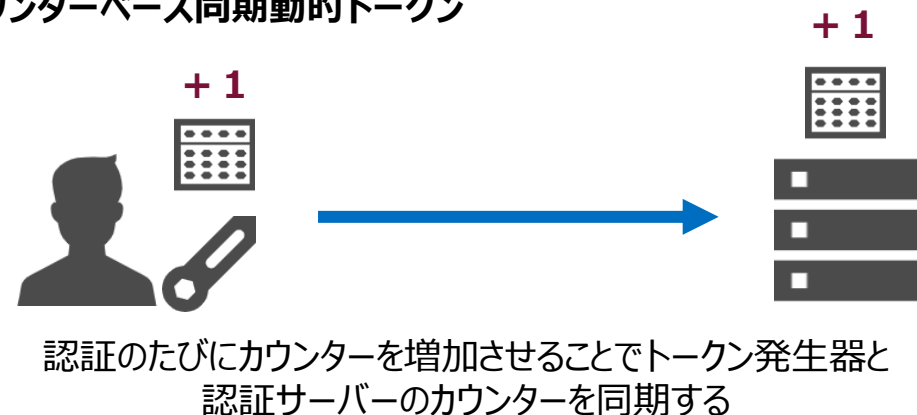
認証タイプ2

●タイプ2：所持による認証方式

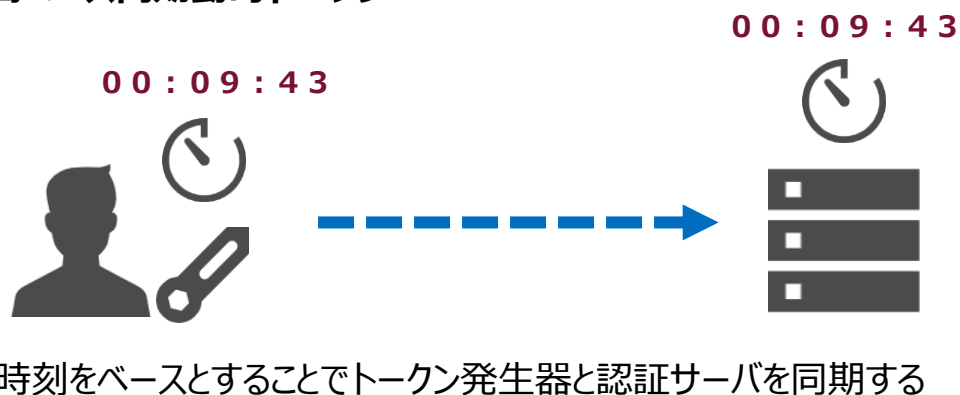
同期動的トークン

- 同期動的トークンは、試行回数や時刻といった認証サーバと同期がとれる情報を用いて発行するタイプのトークンです。
- カウンターベース同期動的トークン**とは、試行回数に同期しながらトークンを発行します。所持する認証デバイスと認証を行うサーバ間で試行回数をそれぞれ数えて置き、試行回数が同じであれば、同じトークンを発行する事ができ認証完了とする方式です。
- 時間ベース同期動的トークン**とは、時刻に同期しながらトークンを発行します。登録した認証デバイスから発行され、かつ同時に発行されたトークンであれば認証できるようになっています。時刻からトークンを発行するため、一定時間でトークンは変更されます。

カウンターベース同期動的トークン



時間ベース同期動的トークン



認証

認証タイプ2

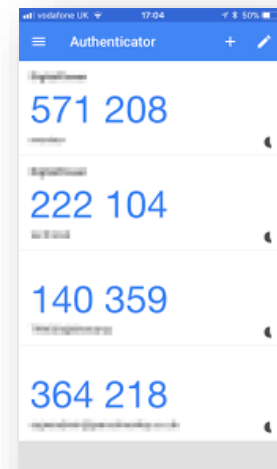
●タイプ2：所持による認証方式

トークン発生器

- トークン認証を行う際、トークン発生器として使うデバイスを登録する必要があります。
- ハードウェアベースとは、RSA SecurIDなどの専用の認証機器を利用して行うものです。
- ソフトウェアベースとは、Google Authenticationなどのアプリケーションをインストールすることで、そのデバイス（多くの場合がスマートフォン）がトークン発生器として動作可能なものです。



RSA SecurID



Google Authenticationの
ワンタイムコード発行

認証

認証タイプ3

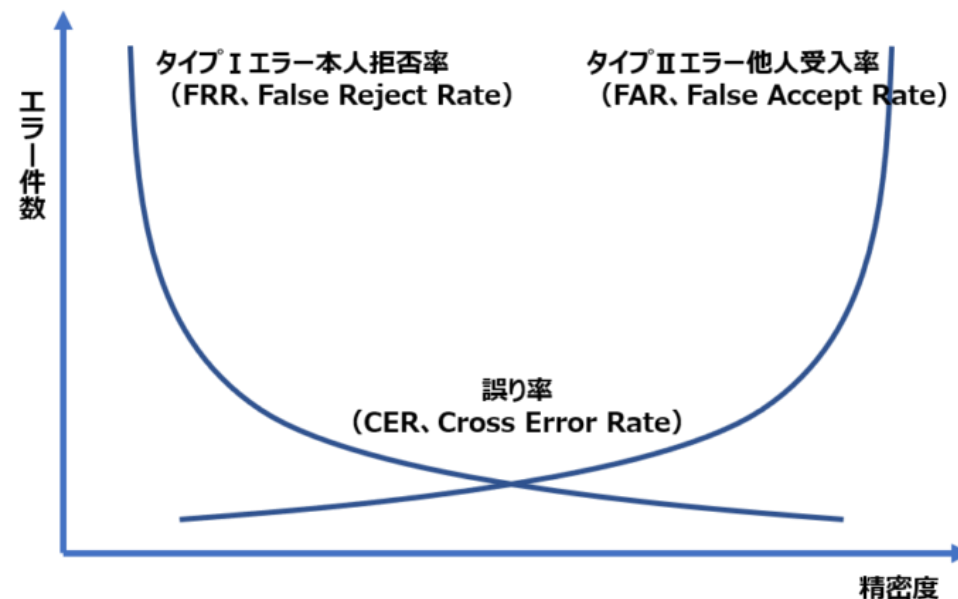
●タイプ3：生体による認証方式

生体認証とは、指紋や顔など自分の体の特徴を使った認証タイプのType3の認証方法です。

生体認証するときには、すべての指紋情報で照合しているわけではありません。例えば、指紋認証においては、指紋同士が交わる部分など認証に利用する指紋情報を適切に選抜しています。

生体認証の精度

- 認証に利用する生体情報を“粗く”することで不利な点もあります。自分以外にも身体的に似ている人がいるかもしれないということです。認証に利用する生体情報の粗さによってほかの人と被ってしまうかもしれません。
- エラー件数と精密度から最も誤り率の低い粒度を探します。タイプⅠエラー本人拒否率とは、ある本人の生体情報に対して本人を拒否してしまったか比率です。タイプⅡエラー他人受入率とは、ある本人の生体情報に対して本人以外の他人を許可してしまった比率です。



誤り率 (CER、Cross Error Rate)
= タイプⅠエラー本人拒否率 (FRR、False Reject Rate)
+ タイプⅡエラー他人受入率 (FAR、False Accept Rate)

認証

認証タイプ3

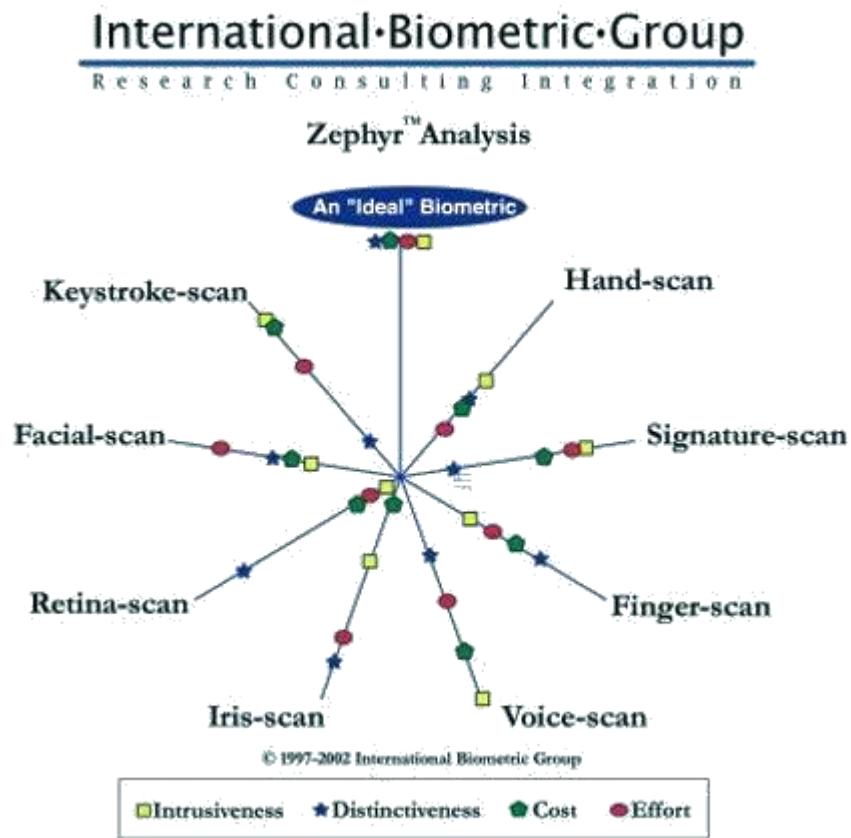
●タイプ3：生体による認証方式

Zephyrチャート

- ・ゼフィアー（Zephyr）チャートとは、各身体部位ごとの精度比較グラフです。
- ・指紋、声帯、虹彩などの比較を行うことができ、本人拒否率・他人受入率・コスト・労力によって評価される。

「ミッション：インポッシブル」の生体認証の突破法

「ミッション：インポッシブル」は、一見侵入不可能と思われる様々なセキュリティを突破するアクション映画です。第1作では、指紋認証を突破するために指紋の成りすましではなく、認証サーバの認証情報を書き換えることで侵入に成功します。第2作では、声紋認証ではボイスレコーダーを使って容易に侵入する様子が描かれています。確かに、Zephyrチャートを見ても指紋認証の侵入は難しく、声紋認証の侵入しやすさはとても高く、IMF（作中の秘密組織）は同じグラフを見ていたかもしれませんね。



Zephyr Chart

(<https://es.m.wikipedia.org/wiki/Biometr%C3%ADa>)

認証

認証タイプ3

●タイプ3：生体による認証方式

FIDO (Fast IDentity Online) Allianceとは、パスワードを使わずに認証を行うための技術の開発と標準化を行う業界団体です。FIDO2は、FIDO Allianceが推し進める認証技術の1つです。

FIDO2およびWeb認証により、WindowsやAndroid端末上で主要ブラウザが対応しており、手元にあるパソコンやスマホがそのままFIDO2対応機器となり、指紋認証や顔認証、虹彩認証といったパスワードを使わない認証処理をオンライン上で実施できるようになります。



FIDO Alliance



FIDO2が体験できるYubico セキュリティキー「 YubiKey 」

認証

認証タイプ3

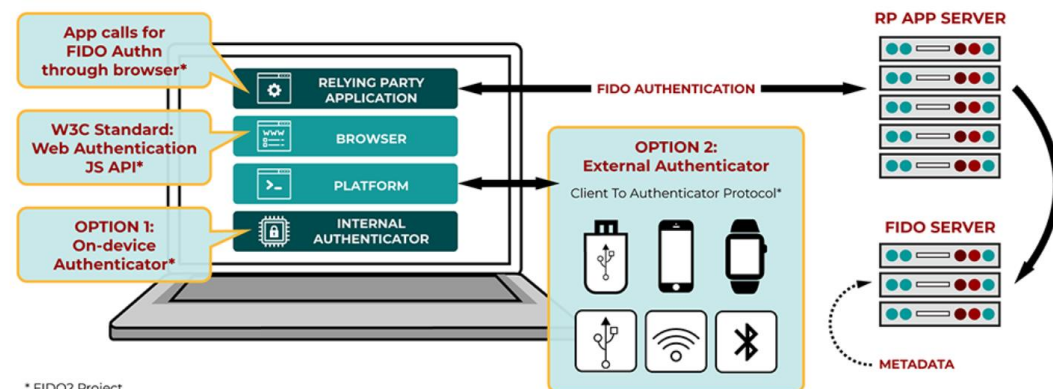
●タイプ3：生体による認証方式

FIDOコンポーネント

- CTAP2とは、FIDO2対応オペレーティングシステム・ブラウザでの認証に外部端末を使用できます。
- W3C WebAuthn（Web認証）とは、FIDO認証のサポートを可能にするためにブラウザおよびプラットフォームに組み込まれている標準Web APIを定義しています。

FIDOの認証方式

- FIDO UAFとは、識別機能を持つ仕様です。指紋認証で誰なのかを確認できます。
- FIDO U2Fとは、追加認証機能を持つ仕様です。パスワード認証などで識別をおこなった上、追加認証としてのセキュリティ強化を行います。



* FIDO2 Project

<https://fidoalliance.org/%E4%BB%95%E6%A7%98%E6%A6%82%E8%A6%81/?lang=ja>

FIDO UAF



サービス
画面

指紋認証

認証完了

FIDO U2F



パスワード
認証

dongleで
認証

認証完了

認可

関連用語

- 権限
- 任意アクセス制御（DAC）
- 強制アクセス制御（MAC）
- アクセス制御マトリクス
- 中央アクセス制御
- 分散アクセス制御
- ロールベースアクセス制御（RUBAC）
- ルールベースアクセス制御（ROBAC）
- 時間ベースアクセス制御
- コンテキスト依存型アクセス制御
- コンテンツ依存型アクセス制御
- 暗黙のDeny
- 制約付きユーザーインターフェース
- データ漏洩防止システム（DLP）

●主体（subject）と対象（object）

アクセス制御をモデル化するとき、アクセス主体とアクセス対象という関係性で整理します。

主体（subject）

- 人間やコンピュータといった、データを操作する側を示す概念です。

対象（object）

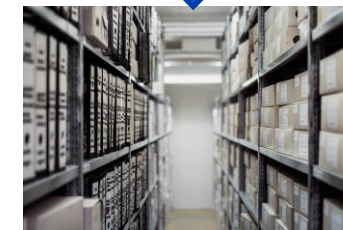
- データそのものやドキュメントなど、データを操作される側を示す概念です。

主体



アクセス
制御

対象



データにアクセスするもの、
アクセスされるに対してアクセス制御を行う

アクセス制御の基本

●主体 (subject) と対象 (object)

主体 (subject) とは、人間やコンピュータといった、データを操作する側を示す概念です。

対象 (object) とは、データそのものやドキュメントなど、データを操作される側を示す概念です。

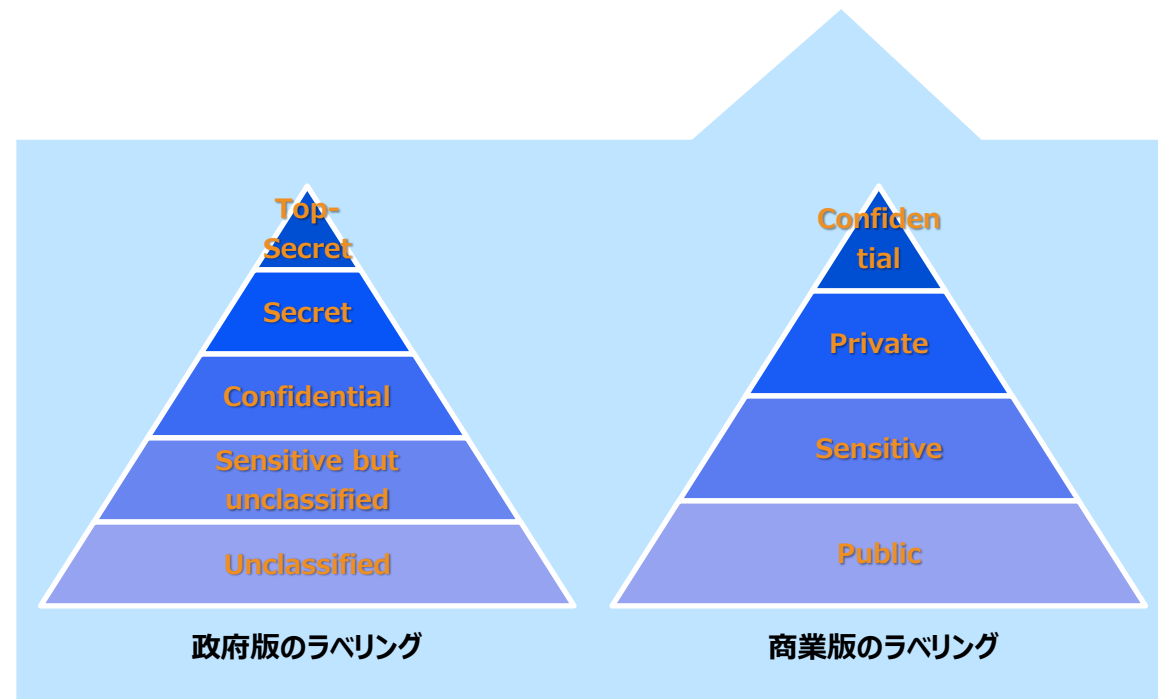
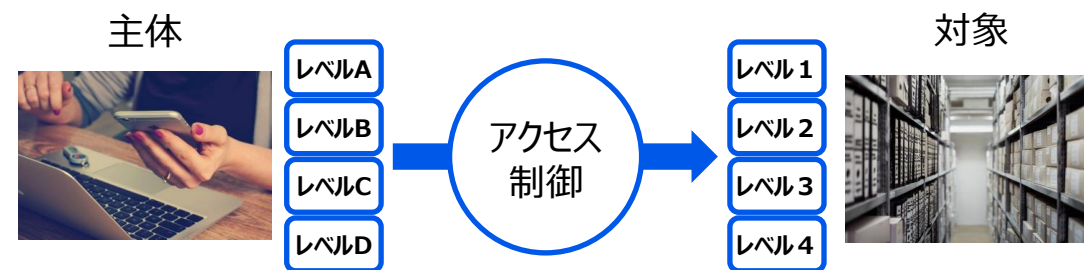
●ラベリングとクリアランス

ラベリング

- オブジェクトを適切な機密レベルに割り当てることです。
- ラベリングの区分と定義は、政府系と商業系で異なります。
- 政府の目的は統治であり、社会データは公開ではなく仕分けを行っていないという扱いになります。一方で、商業の目的は自身の資産であり、社内データは少なくとも認知しておく必要があることから、定義が分かります。

クリアランス

- サブジェクトに対して信頼を基に機密レベルを振り分けた対象にアクセス許可として定義することです。
- 経歴確認等で正当性を担保することでアクセス主体して見なします。



アクセス制御の基本

● 最小権限の原則 (Least Privilege)

最小権限の原則

- 最小権限の原則とは、知る必要のないものには権限を与えないというアクセス制御の原則です。
- 最小権限の原則は、組織での文章やデジタルコンテンツへのアクセス制御やシステムセキュリティを担保するためにも施されます。

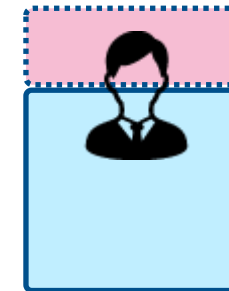
権限適正化のメリット

① 情報漏洩の抑制

- 同じ会社内であっても、ほかの人の給与や住所を知れてしまうと漏洩につながります。アクセス権を絞ることで、個人の権利が保護されます。

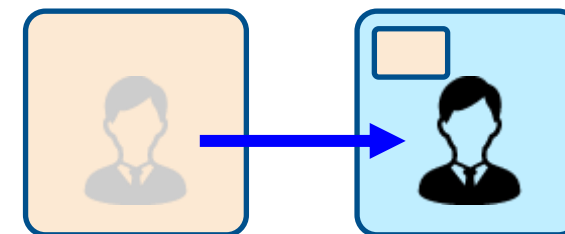
② システム動作の安定

- 不要な権限がないということはその分例外処理が減ります。システム開発やそれに伴うテストを考えた時、不要な権限がないほうが作業が単純化でき、コスト削減としても貢献されます。



権限超過

新しい職に就いたとき、管理者が間違えて大きなアクセス権限を付与していた。



権限クリープ

他のチームに配属になって、職権が変わったのに前の権限が残っていた。

権限違反となるケース

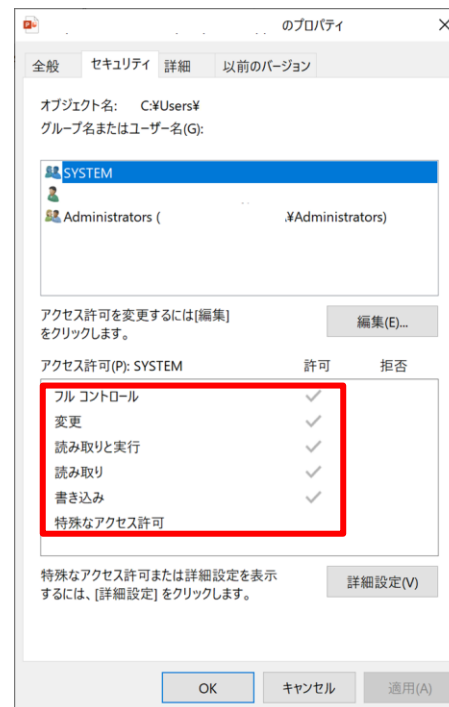
● システムファイルのアクセス制御

任意アクセス制御 (DAC、Discretionary Access Control)

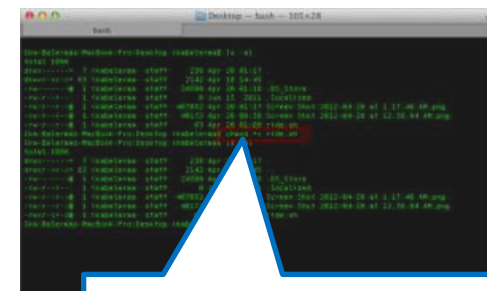
- ファイルの所有者によってアクセス権限が決められ、アクセス対象の所有者であればアクセス権限を変えることができるアクセス制御方式です。
- UNIXやWindowsは、DACに則っています。

強制アクセス制御 (MAC、Mandatory Access Control)

- アクセス権限は、ラベルとクリアランスによって決定されるアクセス制御方式です。
- アクセス主体にはラベルが割り当てられており、アクセス対象のクリアランスがラベルよりも優先される必要があります。
- ラベルは、適切なクリアランスを持つアクセス主体がアクセスできるようにするために使用されます。
- 所有者であろうとも自分のデータファイルに誰がアクセスしてよいか決められず、管理者しかアクセス権限変更できない場合もあります。
- SELinux、TOMOYO Linux、Trusted BSD、Trusted Solaris は、MACに則っています。



Windowsのファイルアクセス設定画面



-rw-r--r-- tom users memo.txt

※memo.txtにtomユーザが読み取り権限と書き込み権限を持っている例

UNIXのファイルアクセス設定画面

● アクセス制御方式

ルールベースアクセス制御（RUBAC、Rule Based Access Control）

- ルールベースでは、組織内の役割や立場に関わらず、あらかじめ決められたルールやアクセス権に従って、アクセスを管理します。すべてのユーザー共通のルールとして設定されたものがルールベースになります。問い合わせできる時間やファイヤーウォールのアクセス設定などがこれに該当します。
- ファイヤーウォールでは、送信元・送信先アドレスによるルールベースでの制御が施されており、他のアクセス制御と組み合わせて実行されます。

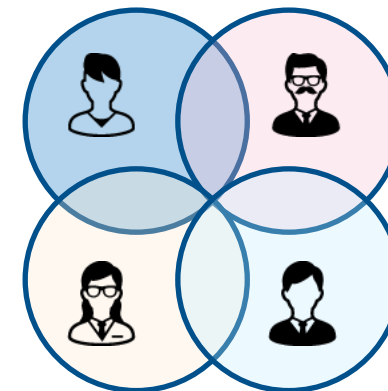
ロールベースアクセス制御（ROBAC、Role Based Access Control）

- アクセス制御元を属性値でカテゴライズして制御することです。
- ロールにアクセス許可が割り当てられ、そのロールのサブジェクトがグループに追加されます。別のポジションに移動すると、そのポジションのアクセス許可グループに移動します。これにより、数千のユーザーと数万のアクセス許可の管理がはるかに簡単になります。



ルールベースアクセス制御

問い合わせ時間など全ユーザー一括で適用されるアクセス制御



ロールベースアクセス制御

役職などの属性値ごとにアクセス権を付与する

● アクセス制御方式

時間ベースアクセス制御 (Time based access control)

- 時間帯によってアクセスを制御することです。
- 準備や問題ないことを確認する時間が必要なのです。そのため、ある時間帯だけは利用できないようにアクセス制御します。

コンテキスト依存型アクセス制御 (Context dependent access control)

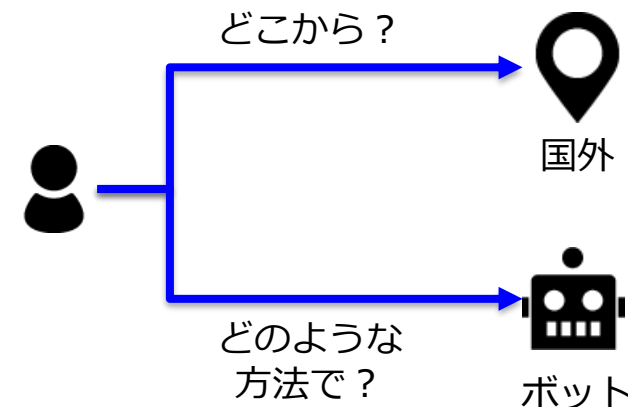
- アクセス対象の集合体 (コンテキスト) としてみた時に、置かれている状態に応じて制御することです。
- ボットかを判定するCAPTCHAなどのチャレンジ/レスポンスメカニズムや、ワイヤレス接続のMACアドレスに基づいてアクセスをフィルタリング、パケット分析に基づいてデータをフィルタリングするファイアウォールはコンテキスト依存のアクセス制御方式の例です。

コンテンツ依存型アクセス制御 (Content dependent access control)

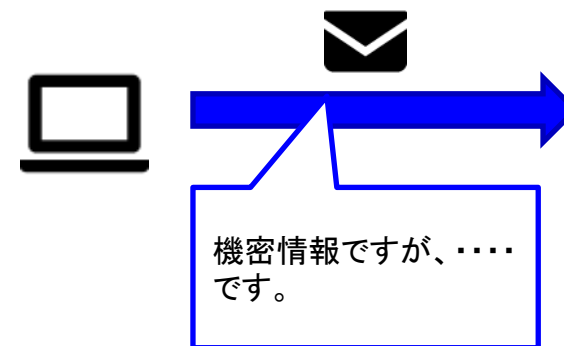
- コンテンツ依存型アクセス制御とは、文面など内容に応じて制御することです。
- 社内から社外にメールを送付したとき、メールの文面に機密情報があれば拒否するなどがこれに当たります。



コンテキスト依存型アクセス制御



コンテンツ依存型アクセス制御





不正ログイン

関連用語

- パスワードハッシュ
- サルト
- 原像攻撃
- ブルートフォース
- パスワードリスト攻撃
- レインボーテーブル
- 辞書攻撃
- 誕生日攻撃
- クリッピングレベル
- キーロガー

不正ログイン

不正ログイン



● 認証の突破

ブルートフォース攻撃

- ブルートフォースとは、パスワードを無作為に当てようとする不正ログインです。
- 一般に試行する文字列は推論や統計的データによって得られたものではなく、ランダムな文字列を生成し、ログイン試行を繰り返します。つまり、パスワードのランダム性の脆弱性をつく攻撃です。

辞書攻撃

- 辞書攻撃とは、単語をパスワードにしているユーザーを狙う不正ログインです。
- 攻撃者は、単語や文章など覚えやすいものをパスワードにしていることを想定し、不正ログインを試みます。

パスワードリスト攻撃

- パスワードリスト攻撃とは、ブラックマーケットなどから取得したログインIDとパスワードで、様々なサイトのログインを試行する攻撃です。
- パスワードは複雑にすると非常に覚えにくいいため、色々なサイトで同じパスワードを使い回しがちです。そのため、脆弱性のある別のサイトから取得したログインIDとパスワードを攻撃対象のサイトで試すと成功する可能性があります。

パスワード認証の終焉は来るのか

Microsoft会長のビル・ゲイツは、「従来のパスワード認証システムは、重要な情報を保護するという課題に対応できないことから、今後廃れていくだろう」と予言した。

そして続けて、「生体認証やスマートカード技術がこれに取って代わるようになる」と述べました。

Microsoftでは社内でもパスワード認証を廃止する運動を行っていることが度々報道されています。



不正ログイン

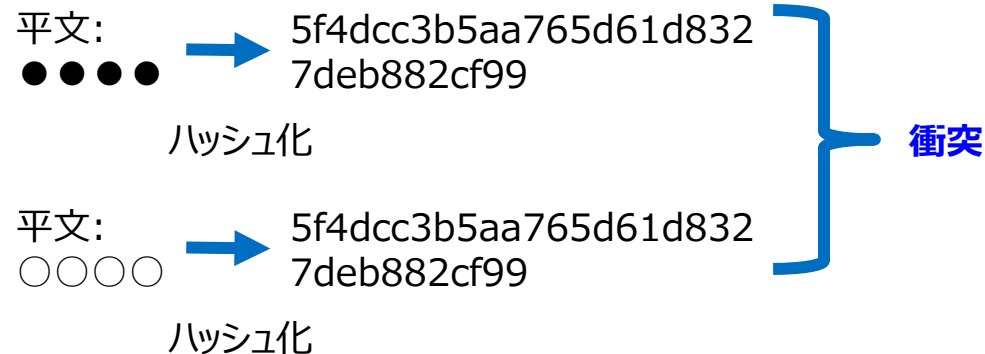
不正ログイン

●パスワードの推測

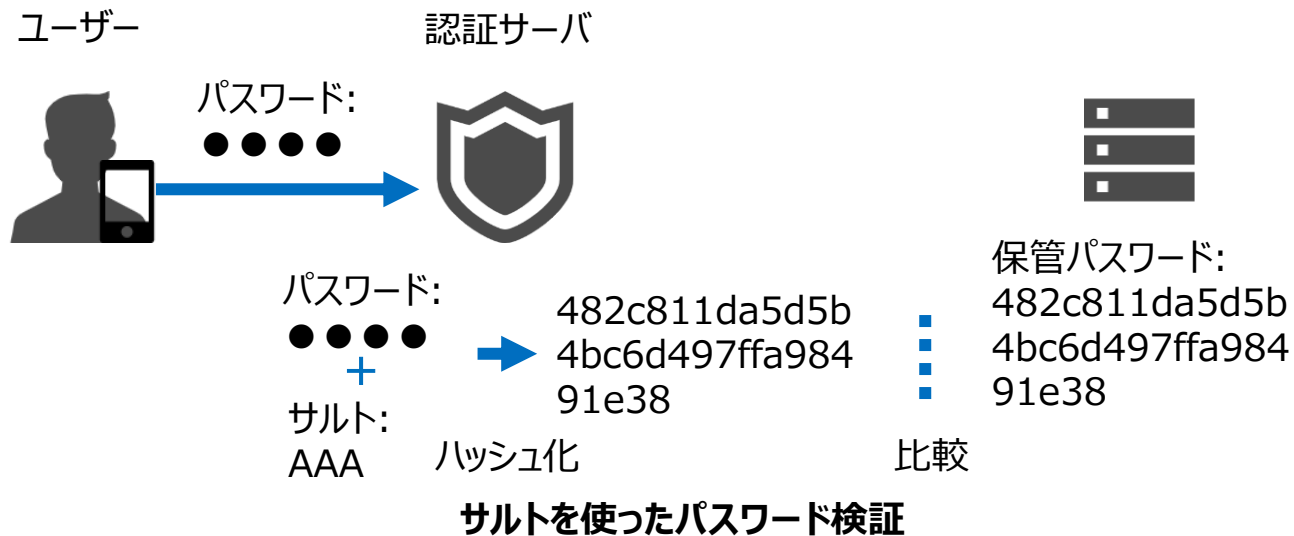
パスワードは平文では保管されていません。一方向暗号化（ハッシュ化）しています。
ログインフォームで入力したパスワードは、認証サーバでハッシュ化し、ハッシュ化済みパスワードと比較されます。

誕生日攻撃

- 少なくとも一つ重なっている確率論により高まった暗号化の衝突を利用して不正ログインを効率的に行うことです。
- 暗号化は他の文字列に変える行為です。別の文字列なのに暗号された結果は同じになるケースもあります。この暗号化の現象を衝突といいます。
- 23人のクラスであれば、同じ誕生日の人がいる確率（＝全員が他の誰とも被っていない確率）はおよそ50%（ $\approx 22/365 + 21/365 + \dots + 1/365$ ）になります。



ハッシュ化した結果が同じ文字列になることによる衝突現象



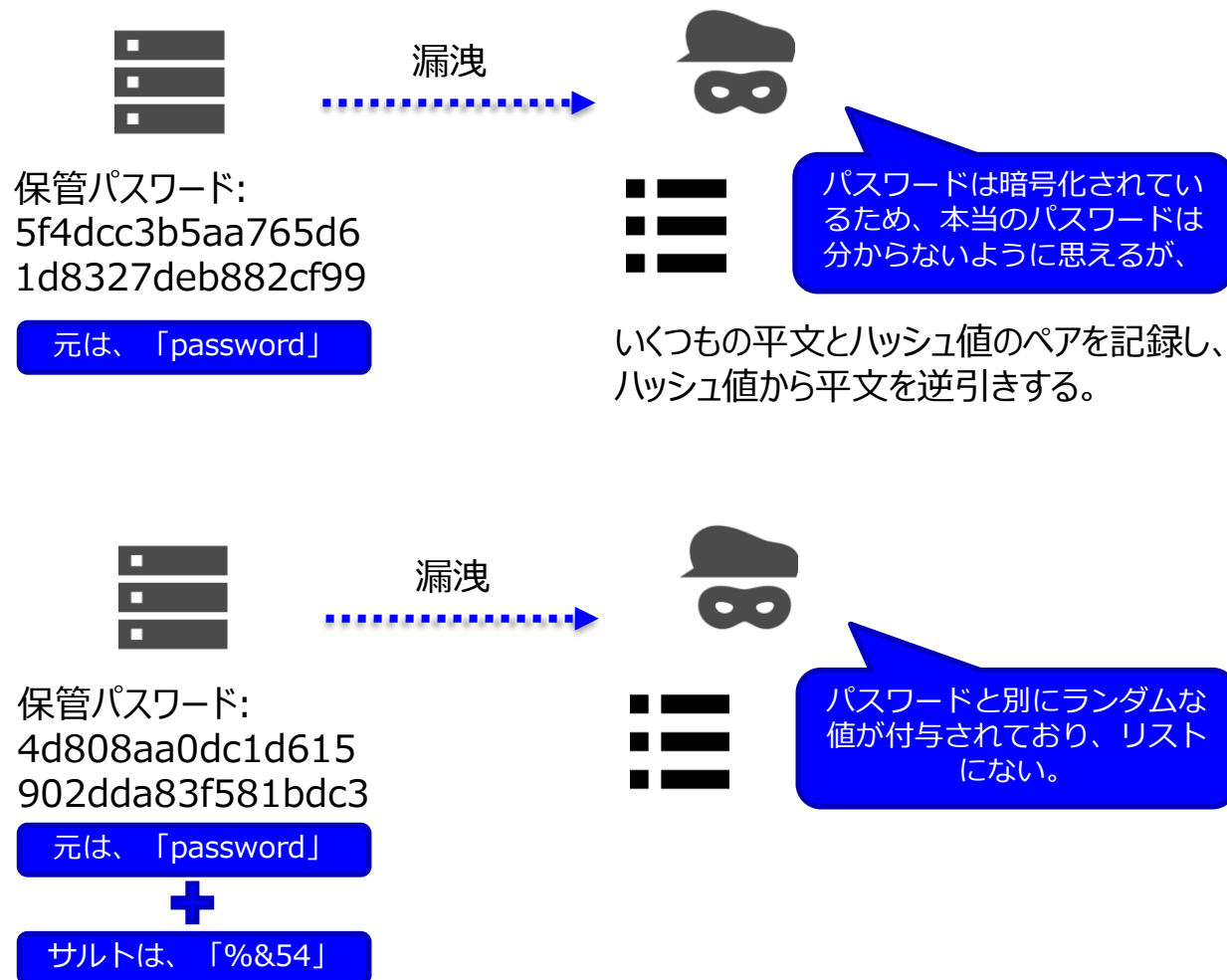


不正ログイン

不正ログイン

● パスワードの推測 レインボーテーブル

- ・ レインボーテーブルとは、暗号化の衝突リストを利用して、不正ログインを効率的に行うことです。
- ・ 平文と暗号文のペアを事前に計算しておくことで逆引きする。
- ・ ランダム文字で形成されるサルトを挿入後、暗号化する事で回避される。レインボーテーブルを作る際には、ある程度パスワードにしそうな文字列からペアとなるハッシュ値を算出しておく。しかし、サルトとして予想困難なランダムな文字列が利用されるため、事前にリスト化しておくことができない。





不正ログイン

不正ログイン

●不正ログインの抑止

パスワードポリシー

- 最大有効期限、最小有効期限とは、同じパスワードを使い続けられる期間です。
- パスワード複雑性とは、パスワード文字列の文字種による複雑性です。推測をさせないために要求されます。
- パスワード長とは、パスワード文字列の長さによる複雑性です。推測をさせないために要求されます。
- パスワード履歴とは、過去に利用されたパスワードの履歴です。過去に使われたパスワードの再利用を抑止します。

クリッピングレベル

- クリッピングレベルとは、アクセス数や処理速度などが正常ではないことを判断するための閾値のことです。ログインを数回間違えた時にロックアウトするなどの何がアクションが必要となるトリガーとなる事象を指すこともあります。
- BtoC向けのサービスでは、一般ユーザーに対して不正ログインによってアカウントロックがかかった場合、すべて解消対応を行うことヘルプデスクの負担が非常に大きくなります。そのため、不正ログインによるアカウントロックは行って期間で自動解除する機能、もしくは自身で解除するセルフパスワードリセット機能を取り込みます。

パスワードの定期変更は不要？

従来はパスワードは推測されないように、定期的に変更することが一般的なパスワードポリシーでしたが、現代では“定期変更しない”ほうが主流となっています。理由は、パスワードを定期変更を要求すると、パスワード記憶の負担から、かえって簡単なパスワードに変更してしまうリスクを加味したものになります。これは、2017年、NIST SP800-63-B (<https://openid-foundation-japan.github.io/800-63-3-final/sp800-63b.ja.html>) の中で示されています。

不正ログイン

不正ログイン

● 機密情報漏洩

キーロガー

- キーロガーとは、コンピュータのキーボード操作を常時記録するハードウェアもしくはソフトウェアです。
- ソフトウェア試験時に、どういった作業をしたか記録を残しておく目的で利用されます。
- しかし、キーの入力などを記録できることで、端末で入力されたのかといった情報を取得することが出来るため、共有で利用するコンピュータにキーロガーを設置して置き、他者の情報を盗み出すなど不正に情報を取得する目的で使われるようになってしまいました。



ハードウェア形式のキーロガー
とても小さく、違和感もない





アカウント管理

関連用語

- プロビジョニング/デプロビジョニング
- オンボーディング/オフボーディング
- ジャストインタイムプロビジョニング

アカウント管理

プロビジョニング



● プロビジョニングライフサイクル

アカウントの登録（プロビジョニング/オンボーディング）

- 適当な入社プロセスを行い従業員として登録が行われます。外部の人間を本人であることを確証するためには、パスポートや運転免許証などの公的証明書が利用されます。
- 証明書の確認後、人事（HR）は従業員の登録作業を行います。アカウントの登録によって、新しい従業員に対し識別情報である従業員番号もしくはメールアドレスと認証情報であるパスワードを割り当てられ、登録アカウントで組織のリソースにアクセスすることを許可します。もし、パスワードだけではなく生体認証といったよりセキュアな認証システムを導入している場合、従業員の指紋登録といったプロセスも発生します。
- オンラインベースの組織では、運転免許証の番号、車を購入した日付といった認証を強度を上げることで対応します。このような認証を行うときには、厳密な時間制限を設けることで悪意のユーザーによる推測を抑止します。公的証明書の写真をアップロードすることを要求するケースもあります。

アカウントの削除（デプロビジョニング/オフボーディング）

- 従業員が会社を離れるとき、速やかにアカウントを無効してください。
- 完全にデータ削除すると退社や退社後において内部犯行的な問題が発生した場合であっても復元処理が困難になるため、管理者がパスワード変更もしくはアカウント停止をし、対象の従業員がアカウントを利用できないようにすることが有効です。
- 退社に関わらず、長期的に利用されていないアカウントを含む不要になったアカウントは適宜削除することです。

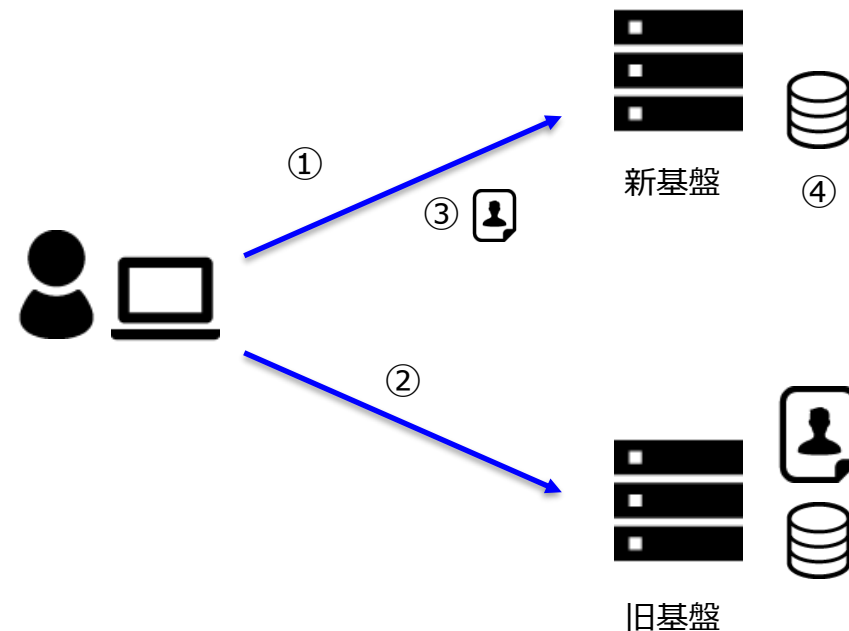
アカウント管理

プロビジョニング

●プロビジョニングライフサイクル

ジャストインタイムプロビジョニング

- アカウント登録する際に、SAML（ Security Assertion Markup Language ） プロトコルを使用して既に登録されている他のサイトからアカウント情報を取得することです。
- アカウント管理者の負担を大幅に減らすことのできるメリットがあります。



- ①新基盤でサービス利用（まだ新基盤にアカウントがない）
- ②新基盤から旧基盤にSAMLリクエスト
- ③旧基盤から新基盤のSAMLレスポンス
- ④受け取ったアカウント情報を新基盤に登録

アカウント管理

プロビジョニング



●プロビジョニングライフサイクル

組織編成が発生するとき、権限違反が行われる危険性があります。そのため、最小権限の原則に則り定期的に権限確認を行う必要があります。

権限超過

- 新しい職種に就いたとき、管理者が間違えて大きなアクセス権限を付与してしまい発生する権限違反。

権限クリープ

- 他のチームに配属になって、職権が変わったのに前の権限が残っており発生する権限違反。

“登録”の表現はクレデンシャルの設定

アカウント登録というと、利用者用に従業員IDなどを払い出すというイメージがしやすいでしょう。本資料では、実際の感覚に近いところから解説したいため、そのような表現にしてみました。

しかしながら、実際には従業員IDがあるからシステムを利用できるのではなく、パスワードを知っているからシステムを利用できます。そのため、従業員IDが払い出されること＝登録＝認証可能は厳密には異なります。

英語の文献では、本人登録とはパスワード（クレデンシャル）を与えることという表現もされますので、読まれる際にはご注意ください。



認証基盤

関連用語

- 中央アクセス制御
- 分散アクセス制御
- シングルサインオン (SSO)
- Diameter
- RADIUS
- TACACS
- 拡張認証プロトコル
- Web of Trustモデル
- OAuth (オーオース)
- OIDC (OpenID Connect)
- Kerberos
- SESAME
- IDaaS
- CASB

認証基盤

シングルサインオン

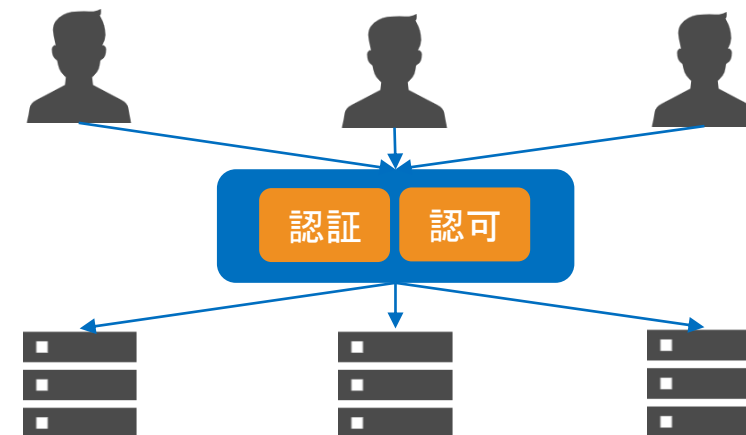
● アクセス制御基盤

中央アクセス制御

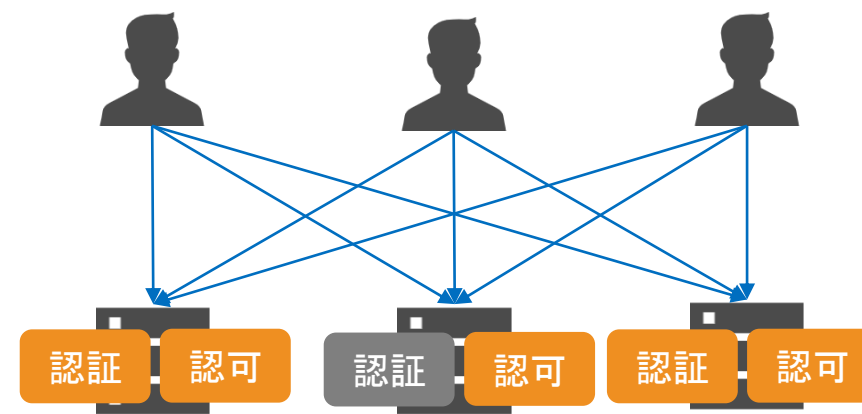
- アクセス制御を行う機構が論理的に集中している体系です。
- 多岐に渡るシステムに対して認証と認可を一か所に統括することを目的にします。
- リバースプロキシ方式である認証基盤ではこのコンセプトに則っています。

分散アクセス制御

- 分散アクセス制御とは認証・認可を一か所に集約するのではなく、個々のシステムで行うことです。
- 拠点では、認証機能を別システムの機能に従属している場合があります。
- エージェント方式である認証基盤ではこのコンセプトに則っています。



中央アクセス制御



分散アクセス制御

認証基盤

シングルサインオン

● シングルサインオン

- シングルサインオン（Single Sign On）とは、一つのログインで複数のサービスを利用できるようにする認証の思想です。
- ユーザーは、パスワードを管理する負担が軽減され、利便性が向上します。

シングルサインオンのメリット・デメリット

- システム開発者は一元化されたシステムはセキュリティ強化観点が明確になります。
- ログインやアカウント管理が一元化される一方で、システムとしては攻撃者に狙われる箇所が1箇所に集約されます。



表：シングルサインオンのメリット・デメリット

メリット	デメリット
一つのログインで済むので、ユーザの利便性も良い。	認証機能をシングルサインオンの機能に譲渡しなければならず、すでにサービス展開していると導入しにくい。
一つのログイン機構で済むので、設計がシンプルになる。	不正ログインに成功すると、すべてのサービスが悪用される可能性がある。
一つのアカウント管理で済むので、運用者にも易しい。	認証機構が一か所に集中していることから大量リクエストによるDoS攻撃に弱い傾向がある。

認証基盤

シングルサインオン

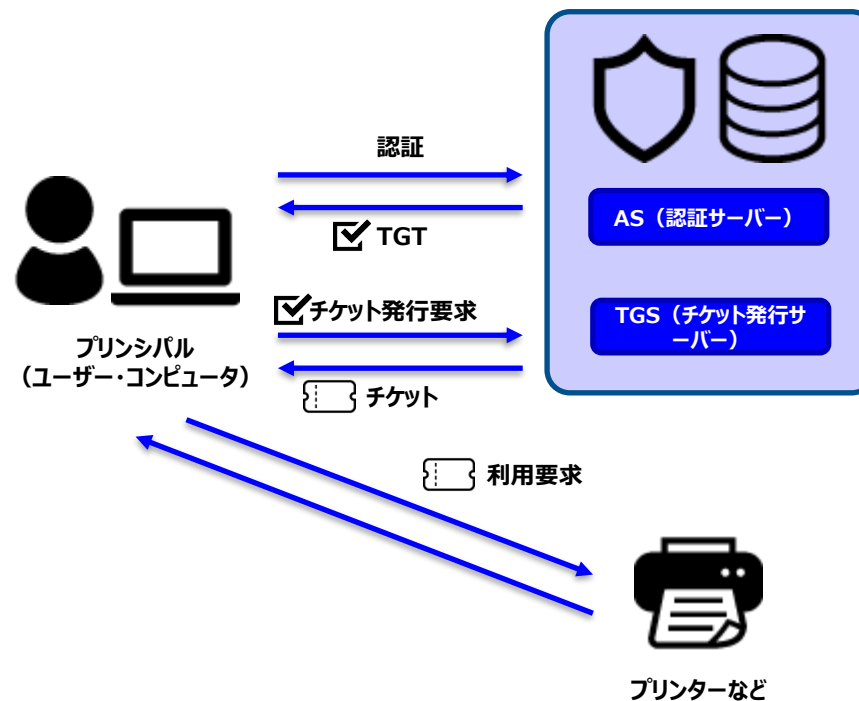
● シングルサインオン

ケロベロス認証、Kerberos

- ユーザー認証した後は、あらゆるサービスにその認証結果を連携することで、ユーザは一回のログインで様々なサービスを利用できるようになります。
- ケロベロス認証が利用されている例として、MicrosoftのActive Directoryがあります。

ケロベロスのコンポーネント

- KDC (Key Distribution Center) とは、ユーザーを認証し、サービスを利用に必要なチケットを発行するための場所です。役割として以下の2つの機能を提供します。
- AS (Authentication Server) とは、本人認証するサーバです。ASはユーザを認証するサーバです。本人確認できるとチケットを発行するためのチケット (TGT、Ticket Grant Ticket) を発行します。
- TGS (Ticket Granting Server) とは、チケットを発行するサーバです。
- プリンシパル (principal) とは、サービスを利用するユーザーやコンピュータです。
- レルム (realm) とは、チケットが使える領域です。



ケロベロス認証のチケット配布

認証基盤

シングルサインオン

● シングルサインオン

SAML (Security Assertion Markup Language)

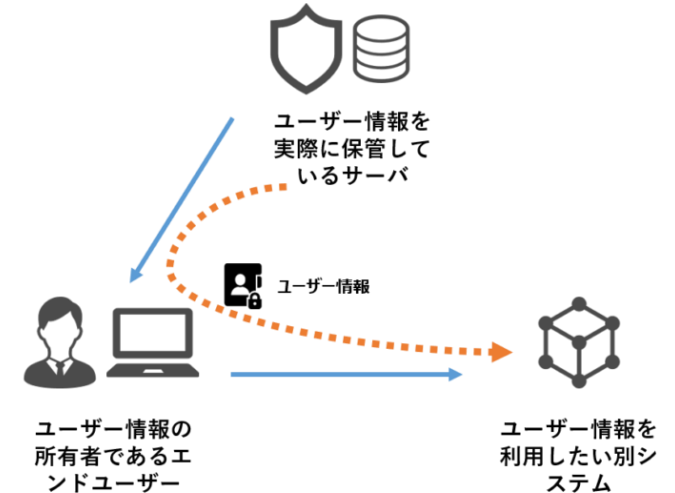
- XMLをベースにした異なるインターネットドメイン間でユーザー認証を行うための標準規格です。
- IdP (Identity Provider) はブラウザ経由でアカウント情報 (アサーション) を連携し、SP (Service Provider) で署名します。

OAuth

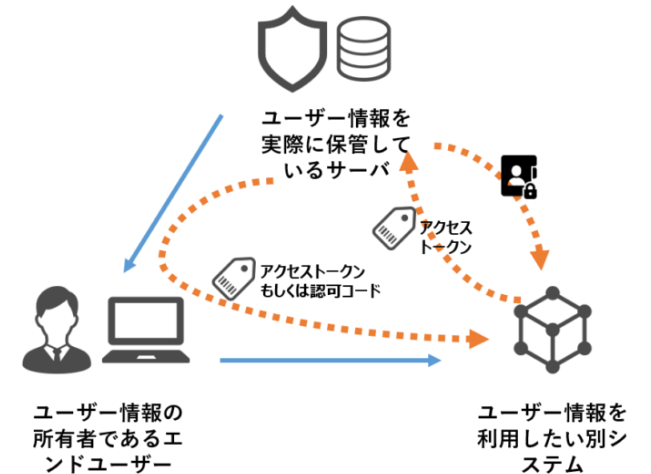
- OAuth (オーオース) とは、の別システムで管理されているユーザー情報照会などのAPIを呼び出すためのフェデレーションの仕組みです。
- 同じフェデレーション仕様にSAMLがありますが明確な違いがあります。SAMLはユーザー認証後にユーザー情報を暗号化して渡すという仕組みです。そのため、アカウント情報を最新化したいときにはユーザー認証を行う必要があります。
- OAuthではユーザー認証・同意許諾後にユーザー情報を渡すのではなくアカウント情報を取得するためのアクセストークンを連携します。OAuthで連携したシステムはアクセストークンを使えばシステム自身が判断して好きなタイミングで最新のユーザー情報を紹介するAPIを呼び出すことができます。当然、同意した内容に沿ったAPIのみが連携可能になります。



SAMLの情報連携



OAuth/OIDCの情報連携



認証基盤

シングルサインオン

● シングルサインオン

OIDC (OpenID Connect)

- OIDC (OpenID Connect) とは、OAuthの後発としてアカウント情報の連携方法、トークン管理を整備した規格です。
- 多少用語の定義や一部のフローがないなどありますが、基本的にはOAuthの規格をOIDCは包含していると考えてよいです。OAuthに、識別連携方法としてIDトークンと最新ユーザー情報取得方法としてのUserInfo APIを整備したものが、OIDCになります。

IDトークン

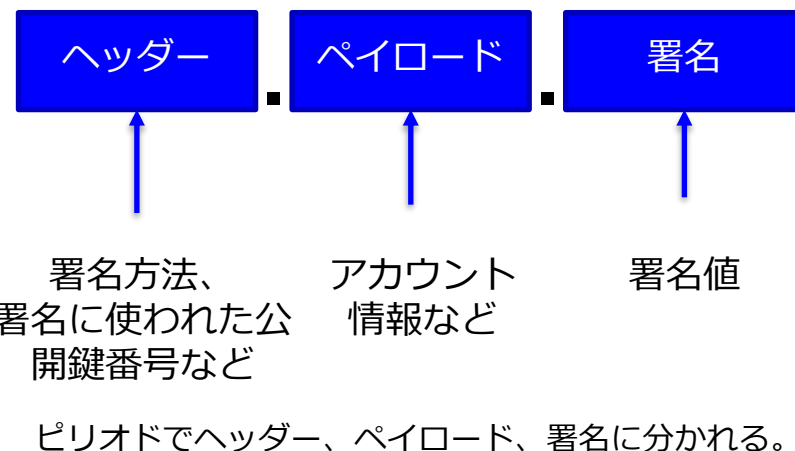
- ID トークンとは、認証されたユーザーの識別情報（名前やメールアドレスなど）に関するクレームが含むJSON ウェブトークン(JWT)です。JSON ウェブトークンは、いわゆる署名付きJSONデータであり、データ改ざんへの防御を持ったフォーマットです。
- OAuthでは、統一された識別情報の連携方法は定義されておりました。



大雑把な仕様の解釈

OAuth2.0 < OIDC

IDトークンの構成



認証基盤

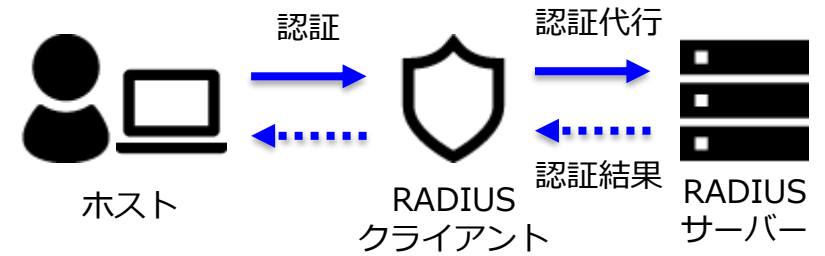
認証プロトコル



● 認証プロトコル

RADIUS (Remote Authentication Dial In User Service)

- RADIUSとは、AAAプロトコルを実現するフレームワークの一つであり、ユーザー認証を要求しリソースに対するアクセス制御を行う際に利用します。
- RADIUSはクライアントがリソースを利用するときに、認証を要求し、確認が取れたらリソースにアクセスさせます。認証するときにはパスワードのみ暗号化します。
- 通信は、UDPで行われます。



RADIUSサーバーが代わりに認証処理してくれる

Diameter

- 前身RADIUSの輻輳等に不便があったため改良しています。
- 通信は、TCPとTLSもサポートしてます。

TACACS (Terminal Access Controller Access-Control System)

- TACACSとは、RADIUSと同じくAAAプロトコルを実現するフレームワークの一つであり、ユーザー認証を要求しリソースに対するアクセス制御を行う際に利用します。
- TACACSは、ネットワーク機器で有名なシスコ独自に提供しています。
- RADIUSでは、認証時にパスワードしか暗号化されないという脆弱性を持っていましたが、TACACSではパケット全体が暗号化します。
- TACACS、XTACACS、TACACS+と改修されており、最新のTACACS+では多要素認証に対応しています。

認証基盤

認証プロトコル

● 認証プロトコル

ポイントトゥポイントプロトコル (PPP、Point to Point Protocol)

- プロバイダとのアクセスのために、サーバーとパソコン間を結ぶために利用するプロトコルです。
- ダイヤルアップ接続などで使われるプロトコルのPPPには、PAP (Password Authentication Protocol) とCHAP (Challenge Handshake Authentication Protocol) という2種類の認証プロトコルが採用されています。
- PAPはパスワードが平文で流れますが、CHAPはチャレンジ・レスポンス方式を採用して、パスワードそのものを経路上に流しません。

拡張認証プロトコル (EAP、Extensible Authentication Protocol)

- リンクの確立段階では認証方式を特定せず、接続の検証段階でEAPタイプと呼ばれる特定のEAP認証方式を使います。
- EAPタイプはクライアントと認証サーバの両方に認証プラグインモジュールとしてインストールされていればよいので、ベンダーはいつでも新しい認証方式モジュールを追加提供できます。



プロバイダーとの接続

表：拡張認証プロトコル

認証方式	内容
EAP-MD5	EAPフレームワークにおけるCHAP認証
EAP-TLS	電子証明書を利用したPKI認証を採用
EAP-TTLS	サーバ側は電子証明書、クライアント側ではユーザー名とパスワードを利用
LEAP	シスコシステムズ独自の認証方式

認証基盤

IDaaS



●IDaaS

- IDaaS (IDentity as a Service) とは、サービスで利用するアカウント情報の管理ログイン負担に弾力性を持たせるためクラウドサービスです。
- 自社でサーバを立てるようなレガシーのシステム環境では、社内領域と社外領域が明確に分かれていました。そのため、領域をファイヤーウォールで区切り信頼の得ないネットワークと信頼の得るネットワークに使い分けができていました。しかし、クラウドサービスが拡大していく中で、社内システムのデータもクラウド上に配置したりユーザー情報の所在が不明瞭になり、「結論、どのネットワークも信用することを前提としてはならない。」というゼロトラストネットワークという概念が生まれました。
- 安全にユーザー情報を連携してサービス展開できるゼロトラストネットワークを実現する一つのアプローチがIDaaSです。
- 有名なサービスには、Microsoft Azure ADやOkta Identity Cloud、OneLogin、Google Cloud Identity、Henge One、Trust Login、Cloud Gate、Oracle Identity Cloud Service、SAP Identity and Access Management、Secioss Linkなどがあります。

OktaがAuth0を買収

2021年5月3日、米OktaはIDaaSを手掛ける米Auth0の買収を完了したと発表した。買収は約65億ドル（約7000億円）相当の株取引によって行われた。IDaaSのリーダーとして一層の業界の加速が狙いだ。しかし、同じIDaaSとして競合でもあるために、時間をかけて統合してより強いシナジーを得ていくと、米Okta COO兼共同創業者のフレデリック・ケレスト氏は説明している。



<https://www.okta.com/jp/blog/2021/04/its-official-okta-joins-forces-with-auth0/>

認証基盤

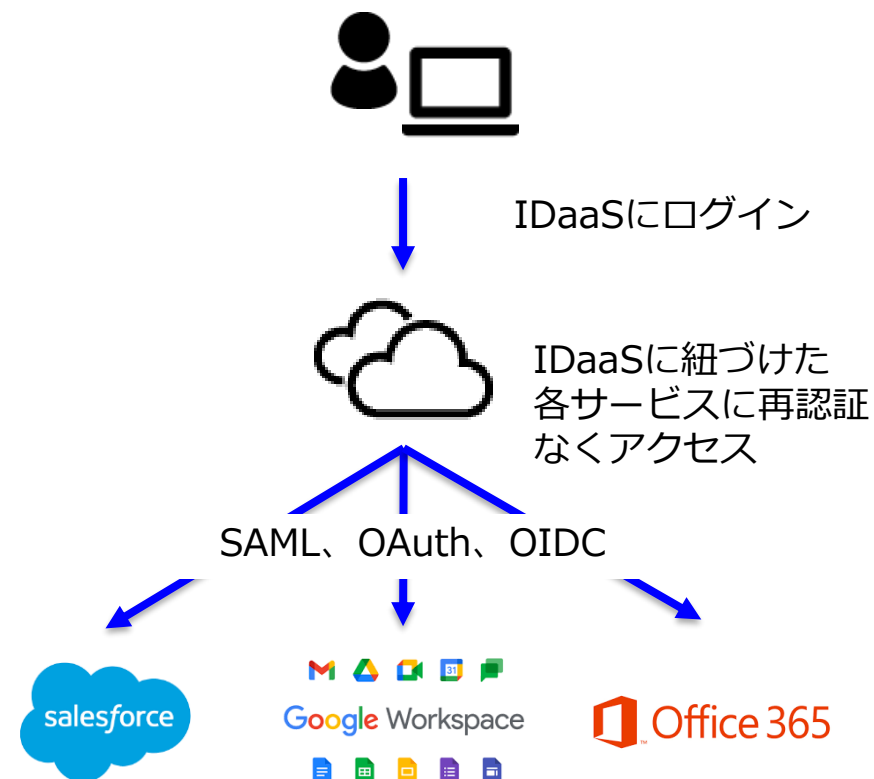
IDaaS



● IDaaS

第3サービスとの統合

- IDaaSの特徴は、シングルサインオンの環境をクラウドサービスとして提供できるということです。
- シングルサインオン環境として、1 回ログインすれば複数のクラウドサービスが使えるようになります。
- IDaaS自身がクラウドサービスを提供するのではなく、クラウドサービスと連携しログインやユーザー情報連携はIDaaSがすべて行うことができます。
- ユーザー情報を連携するためにSAMLやOAuth、OIDCといったフェデレーションやプロビジョニングと呼ばれる機能も取り込まれています。



PIEDPINの紹介



なぜセキュリティを学ぶのか

セキュリティの最も大きな敵は、人はあらゆるものに慣れ、そのリスクを考えなくなる習性にあります。セキュリティの学びを通して得られる貴重なものは、あらゆる事象に対して好奇心を持つことであり、それは目まぐるしい現代を生きるのに大いに役立つでしょう。

- EASY DESIGN
- SUPER EFFICIENT
- EVERYWHERE

PIEDPINを選ぶ理由



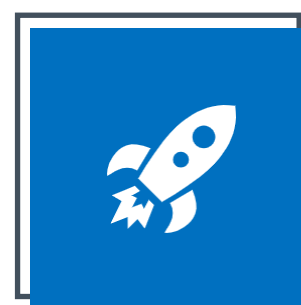
EASY DESIGN

CISSPがすべて日本語で学べる



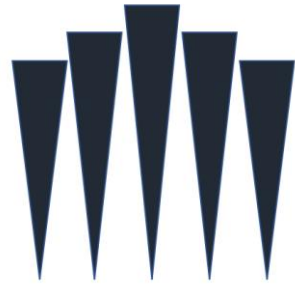
SUPER EFFICIENT

どこよりもわかりやすいメソッド



EVERYWHERE

どこからでも学べる環境



THANK YOU

CISSP for BEGINNER